

Kifisias Avenue 1-3, 11523 Athens
Tel: 210 6475 600 • E: contact@dpa.gr • www.dpa.gr

Athens, 27-06-2024
Protocol No.: 1765

DECISION 17/2024
(Section)

The Hellenic Data Protection Authority convened, following an invitation from its President, in a regular meeting in the composition of a Section at its headquarters on 15/5/2024 to examine the case referred to in the background of this document. The meeting was attended via videoconference by Georgios Batzalexis, Deputy President, due to the absence of the President of the Authority, Konstantinos Menoudakos, the alternate member Maria Psalla, as rapporteur, and the alternate member Dimosthenis Vougioukas in replacement of the regular member Konstantinos Lamprinoudakis who was absent due to an impediment despite being duly summoned in writing. Also present at the meeting, by order of the President without voting rights, was Charis Symeonidou, special scientist – auditor as assistant rapporteur, and Irini Papageorgopoulou, employee of the administrative affairs department of the Authority, as secretary.

The Authority took into account the following:

With the complaint No. G/ΕΙΣ/4277/29-06-2021, A (hereinafter referred to as the complainant) is addressing the company named "METRO Anonymous Commercial and Industrial Company of Food and Household Products" ("METRO AEBE"), (hereinafter referred to as the respondent), alleging an incident of violation of her personal data and failure to satisfy her right of access to her data and deletion of such data. Specifically, according to the complaint, the complainant on ... and on ... placed orders No. ... and ... respectively from the respondent's online store (ehop.mymarket.gr) through the user account she maintains in the said e-shop, under the name "B", in order to receive them at her home, as she was in the ... month of her pregnancy and due to complications was unable to go to a store and carry weight. As stated by the complainant, in the order details she entered her home address and her husband's full name (G) as only this is inscribed on the doorbell. According to the complaint, upon delivery of the orders, the carrier of the respondent company, with whom the complainant states she communicated exclusively via the intercom, refused both times to bring the groceries up to her apartment and forced her to come down to collect them at the entrance of the apartment building, which did not have an elevator. It is noted that, as evidenced by the submitted copy of order ..., the comment "...floor without elevator" has been added. For this reason, the complainant contacted the respondent company on ... to clarify, as she claims, what the correct procedure is, so that if this practice was a policy of theirs, she could choose another chain of stores that would accommodate her situation. During this communication, the respondent confirmed that the complainant had not been served appropriately and provided her with a gift voucher worth five (5) euros for her inconvenience. Subsequently, according to the complaint, on ... the complainant received a call on her personal number which she did not answer and then a message from an unknown number, stating that it was the carrier of the respondent and accused the complainant of his dismissal, ironically giving her "congratulations" for this development. From this incident, the complainant states that she suffered distress and anxiety, which resulted in her being transported to the emergency department of "Elena Venizelou" Hospital, being admitted due to contractions, and staying overnight, fearing for the safety of her pregnancy. Following the above, the complainant with the letter dated ... sent a legal notice.

The complainant protested to the accused company regarding the illegal use of her personal data (mobile phone number) by a former employee of the accused, after the end of his employment relationship with the company. She also requested to be informed about the personal data that the company holds and processes, and requested their deletion. In its extrajudicial response dated ..., the

accused claimed that the former employee likely retained the complainant's personal number, which was mentioned on the delivery note of her order, and that his dismissal was not related to the incident reported by the complainant, but occurred because the accused was dissatisfied with his services. In her complaint, the complainant disputes this response and argues that the accused not only named her as responsible for the dismissal of the carrier but also unlawfully transmitted her mobile number to him after his dismissal, as it is impossible for him to have memorized it among the many customer numbers he serves daily, given that the said carrier did not need to call her during the delivery of the orders, but they communicated via intercom. Furthermore, the complainant states that the company refused to fulfill her rights of access and data deletion that she exercised, claiming that the disputed mobile number may belong to her husband, G, whom it only recognizes as its customer, despite the fact that the orders were placed through the user account that the complainant created under the name "B" and email address ..., thus the company, in any case, has collected and processes her personal data, while her husband's name was mentioned in the orders only because it appears on the doorbell. Additionally, the complainant submits to the Authority the certificate dated ... from the mobile phone provider, which indicates that the mobile number mentioned in the orders belongs to her. Following the above, the complainant complains about the illegal processing of her data by the accused company, which, in her opinion, is due to the absence of appropriate technical and organizational security measures against the risk of unauthorized access to her data by an employee and which caused her moral damage, for the failure to notify the Authority of the incident under Article 33 GDPR, as well as for the failure to satisfy the rights of information, access, and deletion that the complainant exercised in accordance with the GDPR.

In the context of investigating the above complaint, the Authority, with its document G/EXE/2949/20-12-2021, forwarded the complaint and related documents to the accused and invited it to express its views on the allegations. In its response under protocol number G/IE/IE/202/12-01-2022, the accused company responded as follows:

- that on ... and ... through the online store www.eshop.mymarket.gr that it maintains, two orders were placed with numbers ... and ... respectively, in the name of G and with reference to a mobile phone number ending in

- That the company is fully compliant with the legislation on the protection of personal data and that every user, upon registration and when placing an order, is made aware of the Terms of Use (<http://eshop.mymarket.gr/terms>) and the privacy policy (<http://eshop.mymarket.gr/privacy>) that the company maintains, which must be accepted in order to proceed with any action in the said online store.

- That in this case, the company, for the purpose of delivering the orders, provided, as it was obliged to do from the outset, to its competent employee, the necessary documents for each order that included the personal data of the customer, as it had declared.

- That the company requires all its employees to commit by signing a confidentiality statement, a sample of which is provided, according to which employees must not use the personal data that comes to their knowledge in the course of their work for any other purpose than fulfilling their duties, and they commit that they will not reproduce or store them, nor exploit them, while in the event of termination of their cooperation with the company, they will...

5

immediately cease using them, delete them, or return them to the company, and in the event of a breach of the aforementioned obligations, they undertake to compensate for any damage that the company may suffer.

- That the reported incidents are not due to any act or omission of the company and that it had no involvement in them, nor did the dismissal of its employee have any relation to these events, which the company stated from the outset to the complainant, while expressing regret for the inconvenience that the complainant claims to have suffered.

The company lists certain technical and organizational measures it has taken and implements to ensure the confidentiality of the personal data it holds and processes (pages 4-6 of its response), while, regarding the satisfaction of the rights exercised by the complainant with the extrajudicial

statement dated ..., it argues that, as it pointed out in its extrajudicial response dated ..., the request must be made by Mr. G, as the personal data held in the company's database, pursuant to the two aforementioned orders that were made electronically, indicate him as the data subject, while the company is not obliged to know or verify whether the information recorded is true or belongs to another natural person, and requests the dismissal of the complaint.

Following the above document, the Authority, with the G/EXE/189/20-01-2022 transmittal document, forwarded the response of the complained party to the complainant and subsequently, with the G/EIS/1949/08-02-2022 supplementary document, the complainant reiterated her complaint, emphasizing that despite exercising her right to delete her data, she continues to receive the company's newsletter (see attached e-mail from ... to the address ...), that the company unlawfully refused to investigate the incident of her data breach and to notify the Authority, that the complained party does not take care of the return or destruction of the shipping slips, resulting in them remaining in the possession of its employees for an unknown period of time and in this case, after the termination of the carrier's employment relationship, so that the further use of the customers' personal data for purposes other than those of their initial collection is possible. The complainant reiterates

6

the claim that the complained party named her to its employee as the alleged person responsible for his dismissal, while regarding the non-satisfaction of her rights for access and deletion of her data, she states that the company pretentiously continues to assert that its client is G, overlooking the fact that the user account bears the name "B" and the e-mail address ..., and that the shipping details of the order (such as the name and the name on the doorbell) can be modified in each order by the user of the account depending on where they wish it to be delivered, thus she, as the user of the account, is the party transacting with the company and the data subject.

Subsequently, with the G/EXE/696/17-03-2023 document, the Authority communicated the above views of the complainant to the complained party and invited it, within a deadline of 15 days, to provide the Authority with the following information and clarifications, attaching complete documentation details. Specifically, taking into account particularly the following claims included in the G/EIS/202/12-01-2022 response document of the company: i) that the orders ... and ... were made by the client G, with mobile phone number ..., as evidenced by the attached correspondence, an electronic confirmation of the orders from the address info@eshopmymarket.gr was sent to the address ..., ii) that all employees of the complained company are bound by signing a relevant confidentiality statement, a template of which is attached to the above response, and iii) that after the exercise of rights referred to in the GDPR by the complainant, the company pointed out to her that these should be submitted by Mr. G, the Authority requested from the complained party: 1. To provide the Authority with the complete details of the user account of the website <https://eshop.mymarket.gr> from which the orders ... and ... were made (username, contact details, and any other information you have regarding that account), 2. To clarify what actions the complained company took after the exercise of the rights of information, access, and deletion by the complainant through her extrajudicial notice dated ..., stating, in particular, whether the company had doubts regarding the identity of the data subject and if in that case it requested the provision of

7

additional information in accordance with Article 12, paragraph 6 of the GDPR. 3. To provide explanations regarding the fact that, as indicated in the G/EIS/1949/08-02-2022 supplementary document of the complainant, despite exercising the right to erasure of her data as mentioned above, she continued to receive informational messages (newsletter) from the website eshop.mymarket.gr at her email address ..., 4. To clarify whether, after the extrajudicial notice dated ..., the company treated the mentioned incident as a personal data breach and what actions it took in this regard, 5. To submit the confidentiality statement of its employees mentioned in its initial response, signed by the specific employee to whom the reported incidents pertain, and 6. To submit the Data Subject Request Management Policy and the Personal Data Breach Management Policy of the company.

Subsequently, the respondent, after informing the Authority about the need for an extension of the

response deadline (see G/EIS/2366/30-03-2023 informational document), in its G/EIS/3384/08-05-2023 response document, initially stated that it stands by its initial response dated ..., which contains the full user details from whom the orders were placed, namely in the name of G, with the mobile phone number ..., and reiterated that the only person entitled to exercise the rights of information, access, and erasure of the data related to the aforementioned orders is Mr. G, to whom its extrajudicial notice dated ... was communicated (where it is stated: "With this letter, we inform you that the personal data held by our company pursuant to the above orders belongs to Mr. G, who is also the only person entitled to exercise his aforementioned rights by informing our company accordingly, which will immediately comply with his requests"). The company also states that, as the said notice was formulated, "it obviously also had the character of providing additional information, in accordance with Article 12, paragraph 6 of the GDPR" and emphasizes that nevertheless Mr. G did not exercise any relevant right. Furthermore, the company states that, "because through the Authority's letter, it is reasonably inferred today that the email address belongs to the complainant, a fact it was not able to know (previously), it has now proceeded to delete it." The company argues that it did not handle the incident as a data breach, because on the one hand, it responded to the extrajudicial notice dated ... of the complainant with its extrajudicial response dated ..., and on the other hand, the responsible former employee of the company already knew, among other things, the mobile phone number ..., which the customer himself had registered, in order for the order to be sent to the address he had indicated, and the company provided, as it was obliged to do, to the responsible employee the legal documents containing the customer's details, in order to duly complete the delivery of the orders. In the same response, the confidentiality statement dated ... signed by the said employee at the time of his hiring is submitted, while it is emphasized that the reported facts are not due to any act or omission of the company and it had no involvement in them. Finally, the Data Subject Request Management Policy and the company's Personal Data Breach Management Policy are submitted.

In the first of the above documents, titled "Procedures for Responding to Data Subject Requests," the following is provided regarding access requests:

3.1 Data subjects have the right to request access to their personal data being processed. These requests are called access requests. When a data subject submits a relevant request, we will take the following steps:

3.1.1 The date of receipt of the request is recorded (to ensure compliance with the relevant one-month timeline for responding to the request);

3.1.2 The identity of the data subject, who is the subject of the personal data, must be confirmed. For example, we may request additional information from the data subject to verify their identity;

9

3.1.3

searching databases, systems, applications, and other locations where the personal data that is the subject of the request may be processed; and

3.1.4

providing confirmation to the data subject as to whether the personal data of the data subject that constitutes their request is being processed or not.

Similar provisions apply regarding the request for deletion (point 5.2).

In the second of these texts, titled "Procedure for Managing Personal Data Breaches," the following is defined:

7.1 Recognition & Initial Consultation (Step 1)

The successful handling of potential incidents depends on the timely detection and notification of events. For this purpose, the DPO's email will serve as the central reporting channel for all personal data breach incidents, which will provide a mechanism for reporting incidents 24 hours a day, 7 days a week. [...]

Once a personal data breach is detected, the Company's DPO must be immediately notified to ascertain whether the breach is still ongoing. If so, immediate measures must be taken to minimize its impact on the data subjects. [...]

It is of utmost importance that all employees, external collaborators, representatives, partners, and

processors of personal data clearly understand what constitutes an incident and to whom it should be reported.

Once an individual becomes aware that an incident has occurred or is occurring, they must immediately and without delay report the event to the aforementioned Hotline and to the Company's Legal Department (see contact details above).

Following the receipt of notification of a personal data breach, the DPO, with the assistance of the IT department, the NY, and operational teams as required, must contact the individual who initiated the report and conduct an initial assessment of whether an incident has occurred or may be occurring. In the affirmative case, the Company's DPO must:

- Gather information regarding the nature and extent of the incident,
- Determine at an initial level whether there is any reasonable likelihood that the data has been disclosed without authorization or due to improper use, [...]

These actions must be completed within 24 hours of the notification of the personal data breach.

Following the above, the Authority, with its calls G/EXE/530/12-02-2024 and G/EXE/529/12-02-2024, summoned the complainant and the complained party, respectively, to a hearing before the Authority's Department on 21/2/2024, in order to present their views on the case. During the session on 21/2/2024, a postponement was requested by the complained company, the request was accepted, and the discussion was postponed to 6/3/2024. During the session on 6/3/2024, the complainant was present via videoconference through their attorney, Konstantinos Mersinias (Bar Association No. ...), and on behalf of the complained company were the attorneys Dimitrios Smyrnis (Bar Association No. ...) and Aikaterini Dermitzaki (Bar Association No. ...), who were granted a deadline and submitted in due time the complainant's memorandum with reference number G/EIS/2862/27-03-2024 and the complained company's memorandum with reference number G/EIS/2883/28-03-2024.

During the hearing, the representative of the complainant reiterated the claims mentioned in the complaint and its supplementary documents, arguing that in this case, there are more violations, specifically a) the fact that the former employee of the complained company had access to the company's file ... days after the delivery of the order and even after the termination of their employment contract, as they were evidently informed about the complainant's details by the complained company, which seems to have named the complainant as responsible for their dismissal, and b) the violation of their right to access their personal data and their right to deletion, under the pretext that they are not the data subject, but rather their spouse. Furthermore, in their memorandum, the complainant emphasized the consequences of the breach of their data on their health.

11

as well as the fact that the complainant ignored the investigation into the circumstances under which the violation occurred. The complainant reiterated that there was no personal altercation with the employee - distributor and that the distributor had no reason to have stored her phone number on his personal device since he did not use it for the purpose of delivery, much less ... days after the completion of that purpose, while the retail receipt, which contained this phone number and which the respondent refers to, was delivered to the complainant at the time of delivery and could not have been in the possession of the employee after his dismissal. However, from the actual facts, it appears that the fact that the employee accessed her data after the termination of his contract constitutes an incident of violation. Regarding the claim that the data subject is not herself but her husband, the complainant reiterates that she is the data subject as the creator and holder of the account with the username "B" on the respondent's online store, which, despite what was claimed, did not provide any evidence to prove that the account belonged to her husband. Finally, the complainant states that the fact that she did not wish to initiate legal proceedings against the respondent but attempted to resolve the issue extrajudicially should not be interpreted as an "attempt to blackmail" the company on her part and requests the Authority to take all necessary actions so that the respondent refrains from similar incidents of data violation in the future and to fully satisfy her right to the deletion of her personal data file.

The respondent company, both during the hearing and in its memorandum, claimed that the user account bore the name "G," but invoked the fact that to satisfy the right to deletion, the said account

has now been completely deleted, therefore access to it and the submission of relevant evidence to the Authority is not possible. It stated that no rights have been exercised by Mr. G, while it, as the data controller, cannot know if the person behind the screen and entering personal data is the data subject or a third party. Furthermore, it argued that the complainant has the sole purpose of involving the Authority in order to subsequently claim compensation of 20,000 euros, as evidenced by her extrajudicial letter dated Regarding the handling of the incident, the respondent states that it did not handle it as a violation incident because the former employee and distributor already knew, among other things, the mobile phone number at ... which the customer himself had registered, for the purpose of immediate dispatch and proper delivery of the order, and had at his disposal the legal tax documents (retail receipt and delivery note) which include the full details of the customer. Additionally, the distributor had committed to a confidentiality statement, which the company has already submitted to the Authority, and by which he undertook not to use the data that comes to his knowledge during his work for any other purpose, but only for the fulfillment of his duties, not to reproduce or store them, and in the event of termination of his cooperation with the company, he is obliged to immediately cease using them and to immediately return documents or other means that contain personal data, while in case of violation of his obligations, he assumes the restoration of any damage to the company. The company stated that the contract of the said employee, being indefinite, was terminated without cause, without being linked to the incident in question, which he arbitrarily considered to be related to his dismissal. Furthermore, the respondent pointed out that the employee, upon his departure, assured them that he did not have in his possession any personal data, therefore it was impossible for the company to know that contrary to the above statement, the employee had decided to keep the phone number listed on the tax documents due to his altercation with the complainant, which, according to the respondent, had occurred during the delivery. The representatives of the respondent, responding to a related question posed during the session, stated that after being informed of the incident and discovering that the former employee had violated the aforementioned obligations, they sought him but were unable to find him, as in the attempt to contact him by phone...

13

of communication, they closed the phone on him, and in the attempt to notify him of an extrajudicial letter calling him for explanations, it was found that he had changed his place of residence, making delivery impossible. Regarding the handling of the incident, they clarified that the opinion of the DPA was taken into account, which was in agreement with the company's view that this was not a case of violation. In response to a question about whether further measures were taken to prevent similar incidents in the future, the company stated that no action had been taken, but it reserves the right to comply with any suggestions from the Authority. At the same time, the company emphasized that 400,000 customers are registered in its online store and have never had any complaints regarding the processing of their personal data and requested the dismissal of the complaint. The Authority, after examining the file's elements and having heard the rapporteur and the clarifications from the assistant rapporteur, after thorough discussion

CONSIDERED ACCORDING TO THE LAW

1. From the provisions of Articles 51 and 55 of the General Data Protection Regulation (Regulation (EU) 2016/679 – hereinafter, GDPR) and Article 9 of Law 4624/2019 (Government Gazette A' 137), it follows that the Authority has the competence to supervise the application of the provisions of the GDPR, this law, and other regulations concerning the protection of individuals from the processing of personal data. Specifically, from the provisions of Articles 57(1)(f) of the GDPR and 13(1)(g) of Law 4624/2019, it follows that the Authority has the competence to address the complaint of A against "METRO S.A." and to exercise, correspondingly, the powers conferred upon it by the provisions of Articles 58 of the GDPR and 15 of Law 4624/2019.

2. With Article 5(1) of the General Regulation (EU) 2016/679 for the protection of natural persons against the processing of personal data (hereinafter GDPR), the principles that must govern a processing are established.

14

According to Article 5(1)(a), (d), and (f) GDPR: "1. Personal data shall be: a) processed lawfully and fairly in a transparent manner in relation to the data subject ('lawfulness, fairness, and transparency'), [...] f) processed in a manner that ensures appropriate security of the personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, using appropriate technical or organizational measures ('integrity and confidentiality')."

According to Recital 39 of the GDPR, "Personal data should be processed in a manner that ensures appropriate security and confidentiality of the personal data, including protection against unauthorized access to such personal data (...)." Furthermore, according to the accountability principle explicitly stated in the second paragraph of the same article, which constitutes a cornerstone of the GDPR, the data controller "is responsible for, and must be able to demonstrate compliance with, paragraph 1 ('accountability')." This principle entails the obligation of the data controller to be able to demonstrate compliance with the principles of Article 5(1).

3. According to the provision of Article 24(1) GDPR: "1. Taking into account the nature, scope, context, and purposes of the processing, as well as the risks of varying likelihood and severity for the rights and freedoms of natural persons, the data controller shall implement appropriate technical and organizational measures to ensure and be able to demonstrate that the processing is performed in accordance with this Regulation. These measures shall be reviewed and updated when necessary," while according to the provisions of paragraphs 1 and 2 of Article 32 GDPR regarding the security of processing, "1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying likelihood and severity for the rights and freedoms of natural persons, the data controller and the processor shall implement appropriate technical and organizational measures to ensure an appropriate level of security."

15

security against risks, [...] 2. In assessing the appropriate level of security, particular consideration is given to the risks arising from processing, particularly from accidental or unlawful destruction, loss, alteration, unauthorized disclosure, or access to personal data that has been transmitted, stored, or otherwise processed."

4. A personal data breach (Article 4, point 12 of the GDPR) is understood as "a breach of security leading to the accidental or unlawful destruction, loss, alteration, unauthorized disclosure, or access to personal data that has been transmitted, stored, or otherwise processed." According to the Guidelines 18/2018 of the Article 29 Working Party of Directive 95/46/EC (now the European Data Protection Board) on Personal Data Breach Notification ("Guidelines on Personal data breach notification under Regulation 2016/679" WP 250 rev. 1), one type of personal data breach is categorized based on the security principle of "confidentiality," when unauthorized access to personal data is identified ("confidentiality breach"). A breach can potentially have various significant adverse consequences for individuals, which may lead to physical, material, or moral harm. The GDPR explains that this harm may include loss of control over their personal data, restriction of their rights, discrimination, identity theft or misuse, financial loss, unlawful reversal of pseudonymization, damage to reputation, and loss of confidentiality of personal data protected by professional secrecy, etc. (see also recitals 85 and 75). Data breach incidents must be reported to the Authority within 72 hours from the moment the data controller becomes aware of them, according to Article 33, paragraph 1 of the GDPR: "1. In the case of a personal data breach, the data controller shall notify without undue delay and, where feasible, within 72 hours of becoming aware of the breach, the supervisory authority competent pursuant to Article 55, unless the personal data breach is unlikely to result in a risk to the rights and freedoms of natural persons. When notification to the supervisory authority is not made within 72 hours, it shall be accompanied by reasons for the delay." The notification must contain at least the minimum information referred to in paragraph 3 of Article 33 of the GDPR, while according to paragraph 5 of the same article "The data controller documents any personal data breach, comprising the facts relating to the personal data breach, its effects, and the remedial actions taken. This documentation enables the supervisory authority to verify compliance with the present article."

5. Furthermore, the breach must also be communicated to the data subject, as appropriate and in

accordance with the provisions of Article 34, paragraphs 1 and 2 of the GDPR: "1. When a personal data breach is likely to result in a high risk to the rights and freedoms of natural persons, the data controller shall notify the personal data breach to the data subject without undue delay. 2. The notification to the data subject referred to in paragraph 1 of this Article shall describe in clear and plain language the nature of the personal data breach and shall contain at least the information and measures referred to in Article 33, paragraph 3, points (b), (c), and (d)." In assessing the risk, consideration should be given, according to recitals 75 and 76 of the GDPR, to the likelihood and severity of the impact on the rights and freedoms of the data subjects, and the risk should be evaluated based on an objective assessment. According to Guidelines 18/2018 of the WP 29, when assessing the risk to individuals as a result of a breach, the data controller should consider the specific circumstances of the breach, including the severity of the potential impact and the likelihood of its occurrence, taking into account a range of criteria: the type of breach, the nature, sensitivity, and volume of the data, the ease of identifying individuals, the severity of the consequences for individuals, the specific characteristics of the individual, the specific...

17

characteristics of the data controller and the number of affected individuals (wp 250 rev.01, pp. 28-31). 6. The data controller is obliged to facilitate the exercise of the rights of the data subjects as provided in Articles 15 to 22 (Article 12 para. 2 GDPR), which include the right of access under Article 15 GDPR and the right to erasure under Article 17 GDPR, as well as to act in each case upon the request of the data subject based on Articles 15-22 GDPR, informing the data subject within one month from the submission of the request (Article 12 para. 3 GDPR), while if there are reasonable doubts regarding the identity of the individual submitting the request referred to in Articles 15 to 21, the data controller may request the provision of additional information necessary to confirm the identity of the data subject (Article 12 para. 6 GDPR).

7. Furthermore, according to Article 29 GDPR, "The processor and any person acting under the authority of the data controller or the processor, who has access to personal data, shall process those data only on instructions from the data controller, unless required to do so by Union or Member State law."

8. In this case, from the elements of the file and following what emerged during the hearing, the following is established:

With the extrajudicial declaration dated ..., the complainant informed the complained company that its former employee had used personal data (the mobile phone number of a customer of the company) which had come to his knowledge in the course of performing his duties, for a purpose other than the execution of his work and at a time when, according to the confidentiality agreement he had signed, he was obliged in any case to have deleted it. At the same time, he requested a) to be informed by the complained company about the processing of his data and b) to delete his personal data file. The complained company, although it has a Policy for managing personal data breach incidents as a data controller, did not take the appropriate actions to investigate and assess the incident, mistakenly considering that it was not a breach incident, because "the employee lawfully had in his possession the tax documents," as it states, overlooking the fact that these documents had been delivered to the customer upon delivery of the order, and the retention of the mobile phone number on the employee's personal device and its use for other purposes after the termination of his cooperation with the company constitutes a breach of data confidentiality, thus constituting a breach incident within the meaning of Article 4(12) GDPR. The fact that under the relevant confidentiality agreement between them, the said employee has undertaken to remedy any damage to the company does not affect its obligation, as a data controller, on the one hand to notify the incident to the Authority in accordance with Article 33 para. 1 GDPR, and on the other hand to take appropriate actions to handle the incident as referred to in para. 3 of Article 33 GDPR, specifically: to investigate the nature of the incident and the circumstances under which it occurred, to identify the potential consequences for the data subjects, to consider the possibility of taking measures to mitigate those consequences, and to reassess the technical and organizational security measures it implements to prevent similar incidents in the future, in accordance with Articles 24 and 32 GDPR, since the existing measures were not

proven to be sufficient.

Furthermore, it is established that the complained company violated the complainant's right of access to her personal data according to Article 15 GDPR, as a data subject whose data was held by the company in relation to the user account with the name "B" on its online store eshop.mymarket.gr. Specifically, following the extrajudicial declaration dated ..., the company did not check whether it held personal data of the complainant (user account in its online store, username, registration email, order history, etc.) according to the references in points 3.1.2 and 3.1.3 of the submitted Policy for managing requests from data subjects, nor did it request further supplementary information to identify the complainant as a data subject, if it had.

19

reasonable doubts, in accordance with Article 12 paragraph 6 of the GDPR, but was limited to the mention that the two contested orders indicated in the shipping details the full name of the complainant's husband, G. The company did not prove the claim that this account was opened with the details "G", arguing that it no longer had access to it, as it had deleted it in satisfaction of the right to erasure, following the document G/EXE/696/17-03-2023 from the Authority for clarification, after it had determined that the account belonged to the complainant. However, the company did not explain why it satisfied only the right to erasure and not (previously) the right of access that was also exercised by the complainant.

At the same time, it is established that the respondent did not satisfy the right to erasure of the complainant's personal data in accordance with Article 17 of the GDPR, but only after the above-mentioned document from the Authority for clarification, which is evidenced by the fact that the complainant continued to receive newsletters from the respondent company until the beginning of the year In this case, it also appears that the procedures of the respondent company for responding to requests from data subjects were violated, because, despite the submission of a request for erasure by the complainant, the company, as the data controller, did not follow the provisions set out in points 5.2.2 and 5.2.3 of the aforementioned Procedure in order to identify the complainant as the subject of the user account with the name "B" in its online store and with the email address ..., in order to remove her from the list of recipients of its newsletter.

9. Therefore, the Authority finds the following violations on the part of the respondent company, as the data controller:

a) violation of its obligations under Articles 24, 32, and 33 of the GDPR, since although it became aware of the reported incident of breach, it did not proceed with its investigation in accordance with the Policy it has established and did not notify the Authority, nor did it review and update the technical and organizational measures it applies in order to prevent a similar incident in the future,

20

b) violation of the right of access of the complainant, as the data subject, to her personal data held by the respondent for the user account with the name "B" in its online store (eshop.mymarket.gr), which she exercised (as the first request) through the extrajudicial statement dated ...,

c) violation of the right to erasure of the complainant's data under Article 17 of the GDPR, which she exercised through the extrajudicial statement dated ... (as the second request), resulting in her continuing to receive the newsletter until the beginning of the year ... when the complaint was notified to the respondent company.

10. Based on the above, the Authority considers that there is a case to exercise its corrective powers under Article 58 paragraph 2 of the GDPR in relation to the established violations and that, based on the circumstances identified, an effective, proportionate, and deterrent administrative fine should be imposed pursuant to the provision of Article 58 paragraph 2 point (h) of the GDPR, both for the restoration of compliance and for the punishment of the unlawful behavior. Furthermore, the Authority took into account the criteria for assessing the fine set out in Article 83 paragraph 2 of the GDPR, the paragraphs 4 point (a) and 5 point (b) of the same article that are applicable in this case, the Guidelines for the application and determination of administrative fines for the purposes of Regulation

2016/679 issued on 03-10-2017 by the Article 29 Working Party (WP 253), and the Guidelines 04/2022 of the European Data Protection Board for the calculation of administrative fines within the framework of the General Regulation, as well as the factual data of the examined case and particularly the criteria presented below, by violation.

A. Regarding the first established violation mentioned above (see paragraph 9 a), the following specific circumstances are particularly taken into account:

- that the violation of the relevant obligations of the data controller falls under the provision of paragraph 4 of Article 83 of the GDPR.

21

- that the violation resulted in causing distress and adversely affecting the health of the complainant, who was in her ... month of pregnancy
- the fact that the company did not take any action to investigate the incident and mitigate its consequences, arguing that it does not recognize the complainant as a subject, since the order was made in her husband's name, which is unrelated in this case to the leak of her mobile phone number
- the fact that although the company has taken appropriate organizational measures (confidentiality agreement with employees, Incident Management Policy), it appears that these are not implemented in practice. Specifically, it was found that the prescribed procedure for the return or destruction of data after the employee's departure was not followed in the case at hand, but the company relied solely on his verbal assurance that he had not retained any personal data of customers, while subsequently, despite the alleged breach of the contractual obligations of the former employee, the company did not take any legal action to enforce them nor did it even assess the incident as a breach. Therefore, the relevant organizational measures seem to have been taken to cover the company's related formal obligation, without being genuinely adhered to
- the fact that the company's turnover (gross revenue) for the last available financial year (2022) amounted to 1.5 billion euros¹.

B. Regarding the second identified violation (see paragraph 9 b), the following are particularly taken into account:

1 <https://www.metro.com.gr/getattachment/Etaireia/Oikonomika-stoixeia/%CE%95%CE%9D%CE%9F%CE%A0%CE%9F%CE%9B%CE%99%CE%9C%CE%95%CE%9D%CE%9F%CE%A3-%CE%99%CE%A3%CE%9F%CE%9B%CE%9F%CE%93%CE%99%CE%A3%CE%9C%CE%9F%CE%A3-%CE%9C%CE%95%CE%A4%CE%A1%CE%9F-2022.pdf.aspx>

22

- that the violation of the rights of data subjects falls under the provision of paragraph 5 of Article 83 GDPR
- the fact that the complainant made contradictory claims regarding the exercise of rights by the complainant, since ultimately, although it recognized the complainant as a subject, it only selectively satisfied the second request for deletion and not the first request for access to that data
- the degree of responsibility of the complainant, which, although it has established a policy for managing the rights of subjects, did not apply it in this case, in order to request additional information for the identification of the complainant, if it deemed it necessary
- the fact that due to the actions of the company, as the data controller, the satisfaction of the right became impossible, resulting in the complainant being in a worse evidentiary position and unable to exercise her further rights

C. Regarding the third identified violation (see paragraph 9 c), it is particularly noted that the right appears to have been satisfied in the context of examining the case, while the violation is of minor significance and low severity, with reduced consequences for the subject.

FOR THESE REASONS
THE AUTHORITY

A. Imposes on the company METRO S.A., as the data controller, based on Article 58 paragraph 2 letter (h) of the GDPR, an administrative fine of thirty-five thousand (35,000€) euros, for the identified

violation of its obligations under Articles 24, 32, and 33 of the GDPR.

B. Imposes on the company METRO S.A., as the data controller, based on Article 58 paragraph 2 letter (h) of the GDPR, an administrative fine of ten thousand (10,000€) euros, for the identified violation of the right of access of the complainant under Article 15 of the GDPR.

C. Imposes on the company METRO S.A., as the data controller, based on Article 58 paragraph 2 letter (h) of the GDPR, an administrative fine of five thousand (5,000€) euros, for the identified violation of the right to erasure of the complainant's data under Article 17 of the GDPR.

The President

The Secretary

Georgios Batzalexis

Irini Papageorgopoulou